C3PO
CYBER PROTECT OPERATION

MountSec Corporation

Relatório Pentest
Black Box

Escopo

Foi contratado teste do tipo Pentest Black Box para 2 servidores da MountSec Corporation, a fim de realizar as seguintes ações:

ANÁLISE DAS APLICAÇÕES PUBLICADAS	IDENTIFICAÇÃO DOS RISCOS DE EXPLORAÇÕES E CLASSIFICAÇÃO DE SUAS SEVERIDADES
IDENTIFICAÇÃO DE VULNERABILIDADES	RECOMENDAÇÕES E MELHORES PRÁTICAS DE MITIGAÇÃO DAS VULNERABILIDADES ENCONTRADAS

Máquina 1 - MSBRDESAFIO01

Sistema Operacional:
- Windows Server 2008 R2 SP1

Estrutura física e rede:
- Não tivemos acesso

Principais Aplicações:
- Microsoft Exchange
- Microsoft DNS 6.1.7

PONTOS FORTES

- Política de Senha Forte
- Chave de Registro que impede exploração de vulnerabilidade
- Registro de Eventos

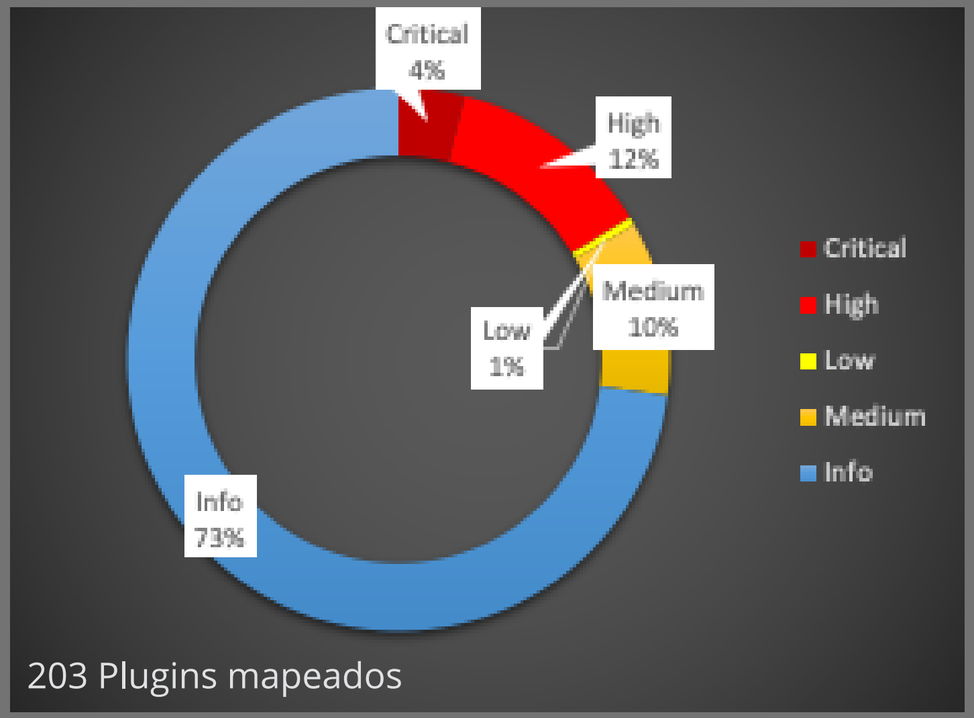
VULNERABILIDADES

- Falta de atualização e instalação de patches de Segurança
- Firewall desabilitado
- Portas abertas com vulnerabilidades críticas associadas
- Arquivos confidenciais desprotegidos
- Falta de Ferramenta para Automação de Backup
- Falta de Antivírus

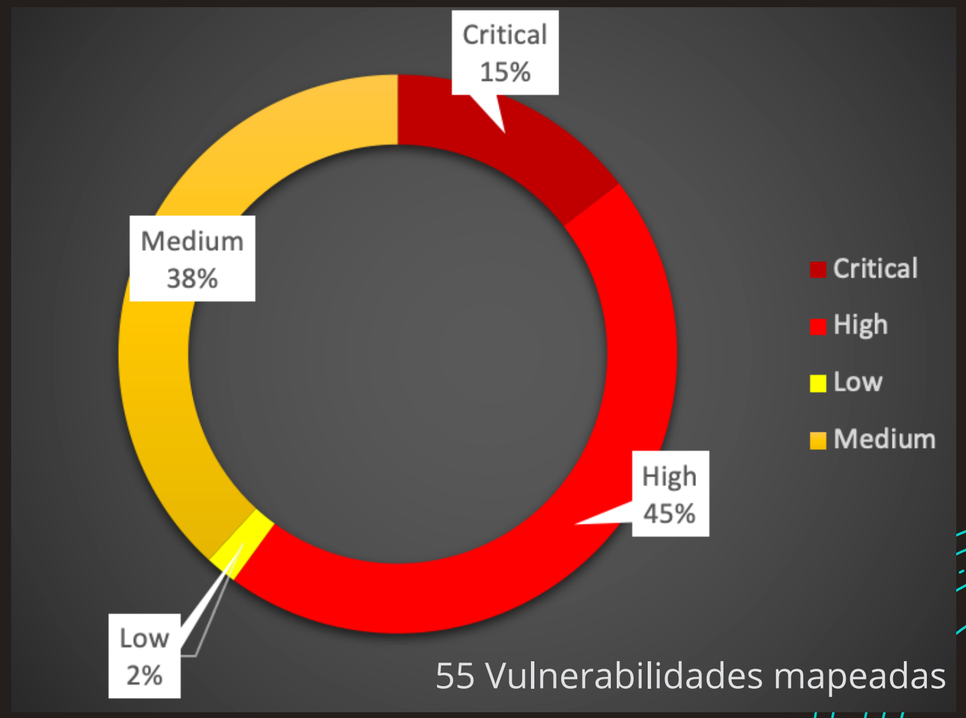
Gráficos

MAQUINA 1

Vulnerabilidade por Severidade NESSUS



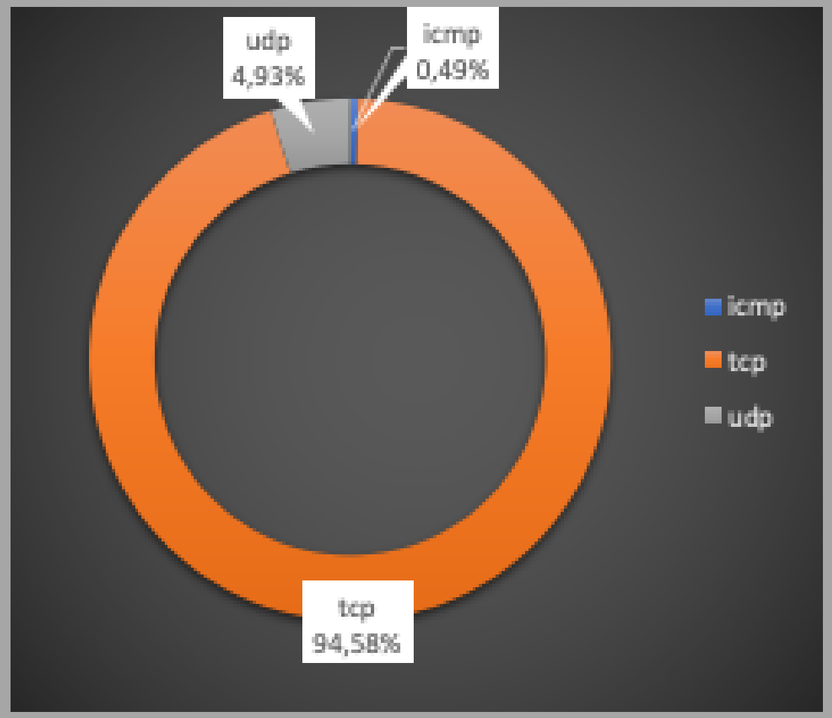
Vulnerabilidade por Severidade [sem informativo] NESSUS



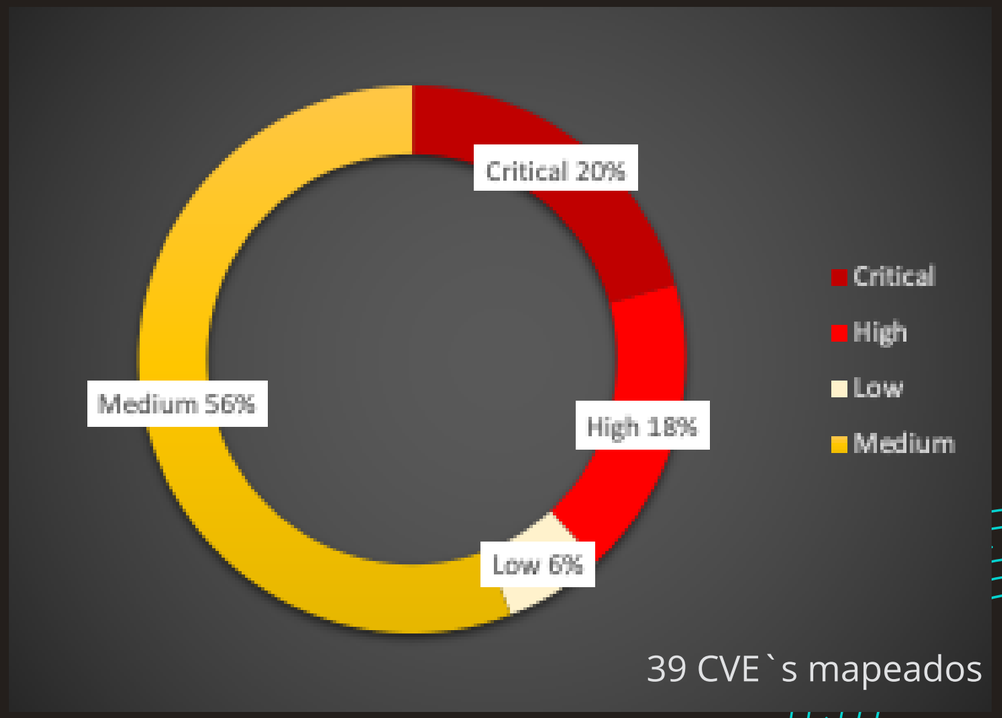
Gráficos

MAQUINA 1

Protocolos mais afetados NESSUS



Severidade por CVE NESSUS - 39



39 CVE`s mapeados

Avaliação de Segurança

MÁQUINA 1

VULNERABILIDADES	RECOMENDAÇÕES
CVE-2017-0144 (ETERNALBLUE)	• SUBSTITUIR O SISTEMA OPERACIONAL (SEM SUPORTE) OU • ATUALIZAR COM OS PATCHES DE SEGURANÇA DISPONÍVEIS
CVE-2019-0708 (BLUEKEEP)	• SUBSTITUIR O SISTEMA OPERACIONAL (SEM SUPORTE) OU • ATUALIZAR COM OS PATCHES DE SEGURANÇA DISPONÍVEIS • CONFIGURAR A CHAVE DE REGISTRO FDISABLECAM = 1 • HABILITAR O NETWORK LEVEL AUTHENTICATION

Avaliação de Segurança

MÁQUINA 1

VULNERABILIDADES	RECOMENDAÇÕES
ARQUIVOS CONFIDENCIAIS DESPROTEGIDOS	• ATUALIZAR PARA VERSÃO MAIS RECENTE DOS PROTOCOLOS DE SEGURANÇA EM COMUNICAÇÃO UTILIZADOS • ARQUIVAR DADOS CONFIDENCIAIS DE FORMA PROTEGIDA COM CRIPTOGRAFIA E/OU SENHA.
FALTA DE FERRAMENTAS DE SEGURANÇA (FIREWALL, SOFTWARE DE ANTIVÍRUS E SOFTWARE PARA AUTOMAÇÃO DE BACKUP)	• HABILITAR O FIREWALL NATIVO DO WINDOWS • INSTALAR UM ANTIVÍRUS • INSTALAR FERRAMENTA PARA AUTOMAÇÃO DOS BACKUPS PERIÓDICOS.

Ações de Mitigação

MAQUINA 1

- Instalar atualizações das aplicações do Servidor
- Habilitar o Firewall
- Revisar as portas abertas
- Criptografar os documentos e bancos de dados
- Automatizar o Backup
- Instalar Antivírus
- Trocar o sistema operacional para mais recente

Máquina 2 - MSBRDESAFIO02

Sistema Operacional:
Ubuntu 8.04

Estrutura física e rede onde opera:
não tivemos acesso

Principais Aplicações:
PostgreSQL 8.1
MySQL 14.2
Apache 2.2.8

PONTOS FORTES

- Registro de Eventos
- Serviço honeypot

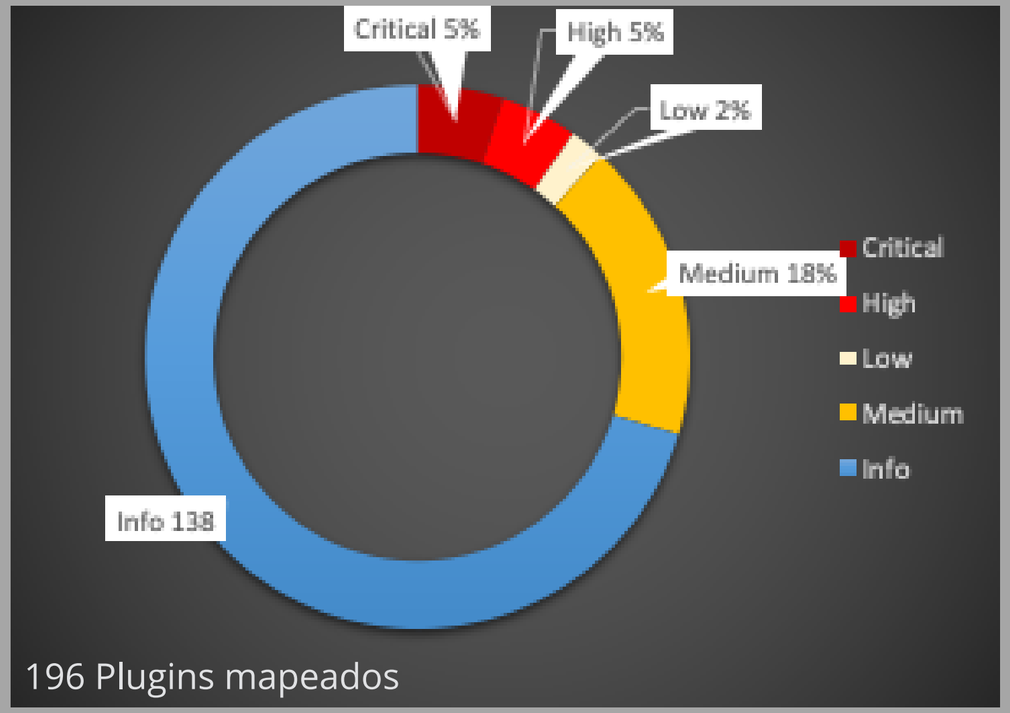
VULNERABILIDADES

- Visibilidade da Versão de Aplicação do serviço Apache
- Portas Abertas
- Serviço FTP desatualizado
- Serviço de ingreslock habilitado
- Misconfiguration

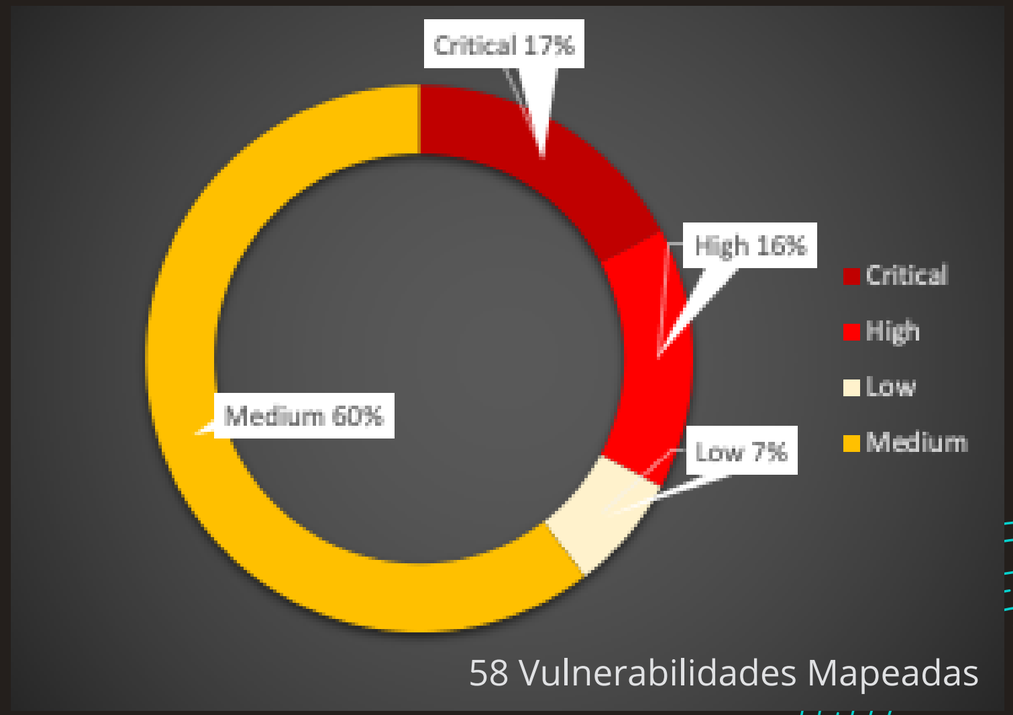
Graficos

MÁQUINA 2

Vulnerabilidade por Severidade NESSUS - 196



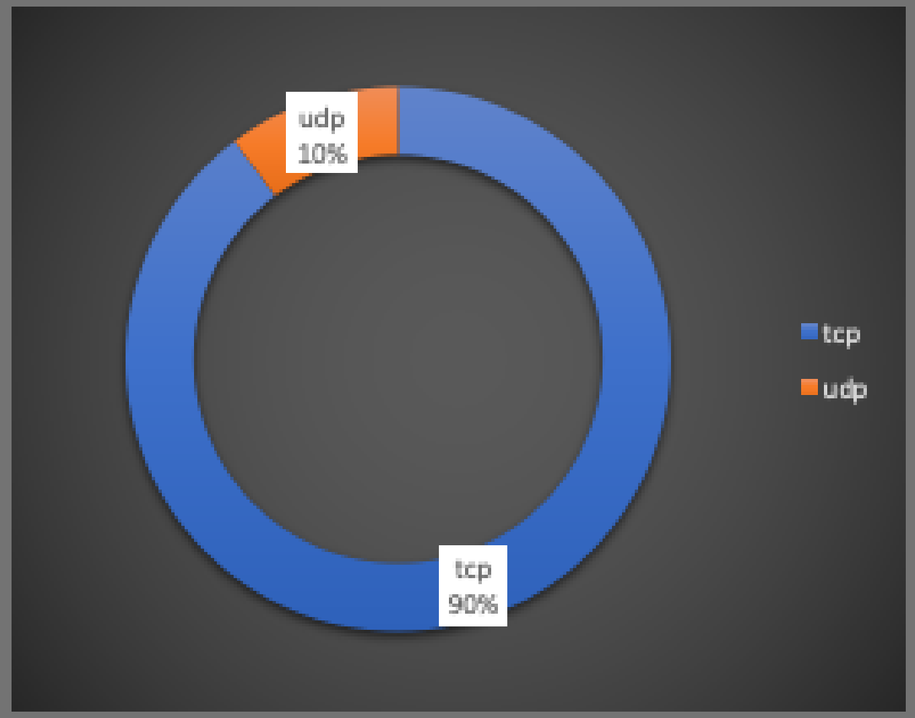
Vulnerabilidade por Severidade [sem informativo - 58] NESSUS



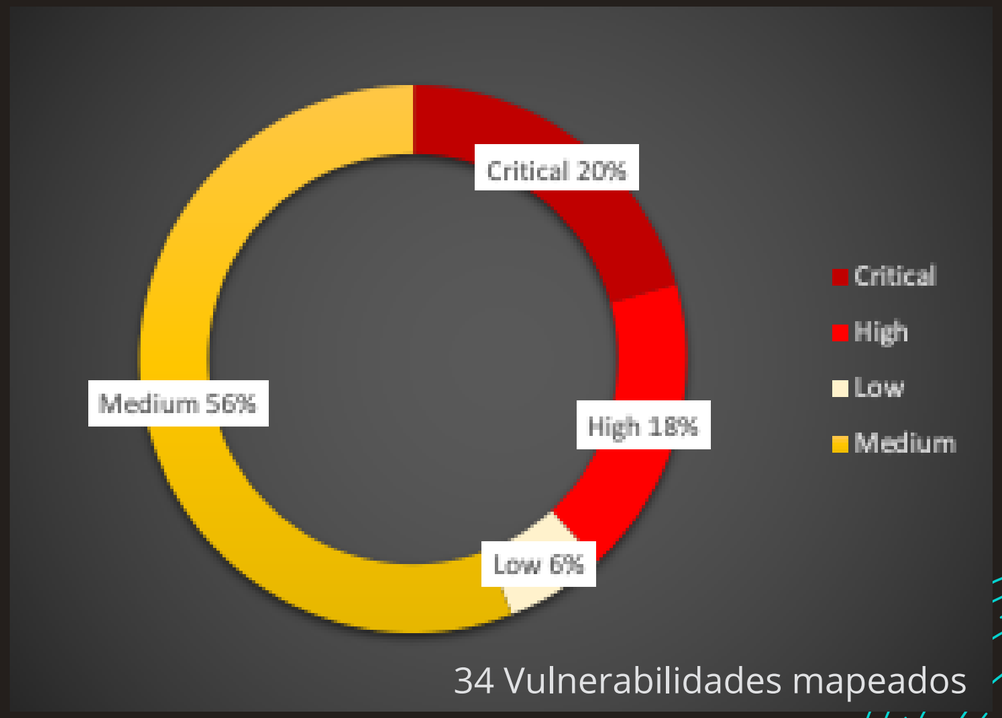
Graficos

MÁQUINA 2

Protocolos mais afetados NESSUS



CVE por Severidade [%] NESSUS - 34



34 Vulnerabilidades mapeados

Avaliação de Segurança

MÁQUINA 2

VULNERABILIDADES	RECOMENDAÇÕES
CVE-2007-2447 - SAMBA SMDB VERSION 3.0.20	ATUALIZAR VERSÃO DO SAMBA.
CVE-1999-0502 - SENHA PADRÃO, NULA, EM BRANCO OU AUSENTE	ADEQUAR SENHAS SEGUNDO O NIST FRAMEWORK.
CVE-2011-3556 - JAVA 1.5.0	ATUALIZAR O JAVA JRE PARA A VERSÃO MAIS RECENTE POSSÍVEL.
CVE-1999-0651 - SERVIÇO RLOGIN	CONFIGURAR CORRETAMENTE SERVIÇOS DE AUTENTICAÇÃO DESATIVAR APLICAÇÕES INSEGURAS
CVE-2007-3280 - POSTGRESQL DB 8.3.1	ATUALIZAR O POSTGRESQL PARA A VERSÃO MAIS RECENTE POSSÍVEL.

Ações de Mitigação

MÁQUINA 2

- Atualizações de versão
- Manter aberta apenas portas de serviços relevantes
- Politicas de senha apropriadas
- Criptografia da documentação e banco de dados
- Corrigir configurações
- Instalação de Antivírus
- Troca de sistema operacional

Obrigado!

C3PO
CYBER PROTECT
OPERATION